Phishing Email Investigation Incident Report

Credential-Harvesting Phishing Email Impersonating ExamplePay

Status: Fictional training case **Verdict:** True Positive — expected training verdict

Evidence status: Header values and findings are simulated. No external scanner results were obtained.

Executive Summary

A fictional email impersonating ExamplePay uses urgent account-suspension language and a lookalike domain. The sample includes simulated SPF/DMARC failures, no DKIM signature, a mismatched Reply-To, a suspicious login URL, and a referenced HTML attachment. Combined indicators support the training verdict of phishing/credential harvesting.

Header Findings

Field	Finding	Status
From	service@examp1epay-support.example; lookalike digit '1'	Simulated
Return-Path	bounce@mail-secure-support.example; domain mismatch	Simulated
Reply-To	recovery.team@freemail.example; different domain	Simulated
Authentication	SPF fail; DKIM none; DMARC fail	Simulated
Received IP	203.0.113.45	Documentation-only IP
URL	hxxps://examp1epay-support[.]example/verify/login.php?id=88231	Fictional/defanged
Attachment	Account_Verification.html (referenced, not included)	No hash available

Verdict and Reasoning

Expected training verdict: True Positive phishing. The lookalike domain, urgent threat, Reply-To mismatch, simulated authentication failures, suspicious login path, and HTML attachment reference are consistent with credential-harvesting phishing. Authentication failure alone would not be sufficient.

MITRE ATT&CK;

T1566.002 (Spearphishing Link) is relevant to the link lure. T1566.001 (Spearphishing Attachment) may apply to attachment delivery, but execution is not demonstrated. T1204 (User Execution) must not be claimed because there is no evidence of user interaction.

Recommended Response (Not Performed)

Search authorized mail gateway and SIEM logs for matching indicators; block confirmed malicious indicators through approved controls; remove matching messages under established procedures; if credentials were submitted, reset credentials and revoke sessions; if an attachment executed, preserve evidence and escalate for endpoint response.

External Checks and Limitations

VirusTotal, URLScan.io, AbuseIPDB, WHOIS, and sandbox checks have not been run. The domains are reserved examples and 203.0.113.45 is a documentation address, so meaningful live reputation results are not expected. Collect genuine screenshots and analyze 5–10 public samples in an isolated VM as a separate manual task.

Prepared as an educational deliverable. Fictional data must not be represented as a real incident investigation.